

Prime Stack Test Execution Report

Team: Prime Stack
Application under test: Frost Inventory and Shopping System
Report date: 18 May 2026

1. Execution Summary

Testing was performed for the Frost Inventory and Shopping System in the local development environment. The testing effort included automated backend functional tests, Playwright UI/usability scenarios, k6 performance and security scripts, and an OWASP ZAP automated scan of the backend API.

The final defect list contains eight confirmed defects because the previous purchase `userId` defect was removed. DEF-001 through DEF-008 are now the canonical IDs used across all reports.

2. Test Environment

Item	Value
Backend	Express API on <code>http://localhost:3000</code>
Frontend	Angular app on <code>http://localhost:4200</code>
Database	MySQL database <code>frost</code>
Functional tools	Jest, Supertest
Frontend/usability tool	Playwright
Performance/security script tool	k6
Security scanner	ZAP by Checkmarx 2.17.0

3. Execution Results by Test Type

Test type	Planned	Evidence	Result summary
Functional API tests	36	<code>backend/tests/functionality</code>	Final run passed: 4 suites, 36 tests
Frontend usability checks	3	<code>frontend/tests/example.spec.ts</code>	Playwright scenarios are available for registration/login and product browsing
Performance tests	6	<code>backend/tests/performance/load-test.js</code>	Latest uploaded run is invalid because k6 received no HTTP responses
Security scripted tests	7	<code>backend/tests/performance/security-test.js</code>	Defects were identified and fixed; unreachable run evidence is retained separately
ZAP scan	1 scan	<code>docs/testing/evidence/2026-05-14-ZAP-Secuirty-Report-.html</code>	Header findings recorded under DEF-008

4. Functional Test Execution

Before the fixes, the functional suite showed 3 failing tests. The failures were connected to missing/invalid email handling and purchase SQL interpolation.

After applying fixes, the final functional result was:

```
```text
```

Test Suites: 4 passed, 4 total

Tests: 36 passed, 36 total

```
```
```

```
● ahmet@ahmet-Vivobook-ASUSLaptop-M6500QC:~/WebstormProjects/meanProject$ cd backend
● ahmet@ahmet-Vivobook-ASUSLaptop-M6500QC:~/WebstormProjects/meanProject/backend$ npx jest
t --config jest.config.json --runInBand --silent
PASS tests/functionality/purchase.test.js
PASS tests/functionality/user.test.js
PASS tests/functionality/product.test.js
PASS tests/functionality/supplier.test.js

Test Suites: 4 passed, 4 total
Tests: 36 passed, 36 total
Snapshots: 0 total
Time: 1.578 s, estimated 2 s
Force exiting Jest: Have you considered using `--detectOpenHandles` to detect async operations that kept running after all tests finished?
```

Functional tests passed

5. Frontend Usability Test Execution

Frontend usability tests are written with Playwright. They cover:

- UT-001: New user registration/login preparation flow.
- UT-002: Product browsing/client dashboard flow.
- UT-003: Existing user login flow.

The Playwright screenshots are not used as defect evidence unless a real UI failure is observed.

6. Performance Test Execution

The k6 load test uses this load profile:

| Stage | Duration | Target virtual users |
|-------------|------------|----------------------|
| Normal load | 30 seconds | 5 |
| Load ramp | 1 minute | 20 |
| Stress | 30 seconds | 50 |
| Recovery | 30 seconds | 0 |

Performance acceptance thresholds:

- 95% of requests should complete in under 500 ms.
- Error rate should stay below 10%.

The latest uploaded k6 load result is not a valid performance failure. It shows `status 0`, `http_req_failed 100%`, and `data_received 0 B`, which means k6 did not receive HTTP responses from the backend. This normally happens when the backend server is not running or is unreachable at `http://localhost:3000`.

```

http_req_duration
✓ 'p(95)<500' p(95)=0s

TOTAL RESULTS

checks_total.....: 8880 58.521834/s
checks_succeeded...: 50.00% 4440 out of 8880
checks_failed.....: 50.00% 4440 out of 8880

x PT-001 status endpoint returns 200
  L 0% - ✓ 0 / x 888
✓ PT-001 response time under 200ms
x PT-002 products endpoint returns 200
  L 0% - ✓ 0 / x 888
✓ PT-002 response time under 300ms
x PT-003 products with details returns 200
  L 0% - ✓ 0 / x 888
✓ PT-003 response time under 400ms
x PT-004 suppliers endpoint returns 200
  L 0% - ✓ 0 / x 888
✓ PT-004 response time under 300ms
x PT-005 login endpoint returns 200
  L 0% - ✓ 0 / x 888
✓ PT-005 login response time under 500ms

CUSTOM
error_rate.....: 100.00% 4440 out of 4440
response_time.....: avg=0 min=0 med=0 max=0 p(90)=0 p(95)=0

HTTP
http_req_duration....: avg=0s min=0s med=0s max=0s p(90)=0s p(95)=0s
http_req_failed.....: 100.00% 4440 out of 4440
http_reqs.....: 4440 29.260917/s

EXECUTION
iteration_duration...: avg=3s min=3s med=3s max=3s p(90)=3s p(95)=3s
iterations.....: 888 5.852183/s
vus.....: 1 min=1 max=50
vus_max.....: 50 min=50 max=50

NETWORK
data_received.....: 0 B 0 B/s
data_sent.....: 0 B 0 B/s

running (2m31.7s), 00/50 VUs, 888 complete and 0 interrupted iterations
default ✓ [=====] 00/50 VUs 2m30s
ERROR[0152] thresholds on metrics 'error_rate' have been crossed

```

k6 load run with unreachable backend

7. Security Test Execution

The scripted security test covers:

- SQL injection on login.
- SQL injection in product ID parameter.
- XSS payload in registration username.
- Unauthenticated profile access.
- Mass assignment using `role: "admin"`.
- Oversized login payload.
- Unauthenticated access to `/User/users`.

One uploaded k6 security run also shows `status 0` and `data_received 0 B`. That specific run is invalid for pass/fail grading because k6 could not reach the backend. The security defects themselves were still confirmed by route review and earlier scripted checks, then fixed in code.

```
ahmet@ahmet-Vivobook-ASUSLaptop-M6500QC:~/WebstormProjects/meanProject/backend$ k6 run
tests/performance/security-test.js
INFO[0003] ST-007 Unauth User List: 0 - null source=console

■ TOTAL RESULTS

checks_total.....: 7      2.322529/s
checks_succeeded...: 57.14% 4 out of 7
checks_failed.....: 42.85% 3 out of 7

✓ ST-001 SQL injection on login is rejected
✓ ST-002 SQL injection on product ID is rejected
✓ ST-003 XSS payload in username is handled
x ST-004 protected route rejects unauthenticated request
  ↳ 0% — ✓ 0 / ✗ 1
✓ ST-005 mass assignment does not grant admin role
x ST-006 oversized payload does not crash server
  ↳ 0% — ✓ 0 / ✗ 1
x ST-007 user list requires authentication
  ↳ 0% — ✓ 0 / ✗ 1

HTTP
http_req_duration....: avg=0s    min=0s    med=0s    max=0s    p(90)=0s    p(95)=0s

http_req_failed.....: 100.00% 7 out of 7
http_reqs.....: 7      2.322529/s

EXECUTION
iteration_duration...: avg=3.01s min=3.01s med=3.01s max=3.01s p(90)=3.01s p(95)=3.01s
iterations.....: 1      0.33179/s
vus.....: 1      min=1      max=1
vus_max.....: 1      min=1      max=1

NETWORK
data_received.....: 0 B      0 B/s
data_sent.....: 0 B      0 B/s

running (00m03.0s), 0/1 VUs, 1 complete and 0 interrupted iterations
default ✓ [=====] 1 VUs 00m03.0s/10m0s 1/1 shared iters
ahmet@ahmet-Vivobook-ASUSLaptop-M6500QC:~/WebstormProjects/meanProject/backend$
```

k6 security run with unreachable backend

8. ZAP Scan Results

ZAP report details:

| Attribute | Value |
|---------------|--|
| Tool | ZAP by Checkmarx |
| Version | 2.17.0 |
| Generated | Thu 14 May 2026, 14:16:40 |
| Site | http://localhost:3000 |
| Evidence file | docs/testing/evidence/2026-05-14-ZAP-Secuirty-Report-.html |

ZAP alert summary:

| Alert | Risk | Confidence | Evidence |
|--|---------------|------------|--|
| CSP failure to define directive with no fallback | Medium | High | default-src 'none' without frame-ancestors and form-action |
| Server leaks X-Powered-By | Low | Medium | X-Powered-By: Express |
| X-Content-Type-Options header missing | Low | Medium | /Product/ did not include nosniff |
| User Agent Fuzzer | Informational | Medium | Response changed for an old IE user agent |

9. Confirmed Defects

| ID | Title | Severity | Status |
|---------|---|----------|--------|
| DEF-001 | Missing/invalid email returns 500 instead of 400 | Medium | Fixed |
| DEF-002 | Template literal bug in <code>getPurchaseByUserId</code> | Medium | Fixed |
| DEF-003 | <code>SupplierRoute</code> POST has no error handling | Medium | Fixed |
| DEF-004 | Login route hardcodes status 500 | Medium | Fixed |
| DEF-005 | Mass assignment allows any user to register as admin | Critical | Fixed |
| DEF-006 | <code>/User/users</code> exposes all user data without authentication | High | Fixed |
| DEF-007 | XSS payload stored in database without sanitization | Medium | Fixed |
| DEF-008 | Missing security headers | Low | Fixed |

10. Overall Assessment

The application now has stronger automated coverage for core API behavior and the confirmed defects have corresponding fixes. The main remaining documentation action is to re-run k6 performance with the backend server running so the result shows real HTTP status codes instead of `status 0`.

11. Evidence List

| Evidence | File |
|-------------------------------|--|
| ZAP full report | <code>docs/testing/evidence/2026-05-14-ZAP-Secuirty-Report-.html</code> |
| DEF-001 before/after evidence | <code>docs/testing/evidence/defects/def-001-*.png</code> |
| DEF-002 before/after evidence | <code>docs/testing/evidence/defects/def-002-*.png</code> |
| DEF-004 login status fix | <code>docs/testing/evidence/defects/def-004-login-statuscode-fix.png</code> |
| DEF-005 mass-assignment fix | <code>docs/testing/evidence/defects/def-005-mass-assignment-fix.png</code> |
| DEF-006 user-list auth fix | <code>docs/testing/evidence/defects/def-006-user-list-auth-fix.png</code> |
| DEF-007 XSS validation fix | <code>docs/testing/evidence/defects/def-007-xss-username-validation-fix.png</code> |
| DEF-008 security headers fix | <code>docs/testing/evidence/defects/def-008-security-headers-fix.png</code> |
| Functional pass screenshot | <code>docs/testing/evidence/defects/functional-after-36-passed.png</code> |
| Invalid k6 load run | <code>docs/testing/evidence/defects/performance-unreachable-run.png</code> |
| Invalid k6 security run | <code>docs/testing/evidence/defects/security-unreachable-run.png</code> |